

Étude des services ISO 27002

Sécurité des Systèmes d'Information

Paul VEROT
Master II CNS-SR, 2026



UNIVERSITÉ ÉVRY
PARIS-SACLAY



UNIVERSITÉ ÉVRY
PARIS-SACLAY

Département d'informatique

univ-evry.fr

portfolio.paulverot.fr

Titre:

Étude des services ISO 27002

Thème:

Sécurité des Systèmes d'Information

Groupe:

Master II CNS-SR

Participants:

Paul VEROT

Email:

20212888@etud.univ-evry.fr

pauljeanlouisverot@protonmail.com

Superviseur:

Damien PLOIX

Nombre de pages:

9

Dernier changement:

18-09-2026

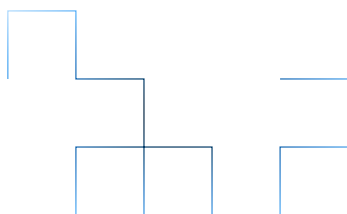
Résumé:

--

Contents

1 Contexte	2
1.1 Question	3
2 ISO 27002	4
2.1 Sauvegarde des Informations	5
2.2 Changement de Gestion	5
2.3 Ségrégation des environnement de developpement et production	5
2.4 Relation fournisseur/client	6
3 Analyse d'un cas réel : TSB 2018	7
Références	9

Contexte



L'entreprise AlphaBeta, distributrice de dentifrice, emploie des VRP (Vendeurs/Représentant/Placiers) pour placer ses produits dans les grandes surfaces sur l'ensemble du territoire français. Elle souhaite mettre en place une solution de mobilité sur tablette et smartphone Android. Cette application permettra à chacun de ses vendeurs d'informer un système centralisé :

- du magasin dans lequel chaque vendeur se trouve,
- du niveau de stock présent dans les rayons.

Cette application traitera de données sensibles puisqu'elle permettra de calculer le chiffre d'affaire réalisé.

La réalisation, l'hébergement et l'exploitation de l'application est confiée à une jeune startup EvryTop créée par des étudiants de l'université d'Evry. À l'occasion de la mise en service de la nouvelle version de l'application, il s'avère que les données de production sont corrompues et qu'il est très difficile de récupérer les anciennes valeurs. Pour corriger le problème, il a été demandé à l'ensemble des vendeurs de réaliser une nouvelle saisie de leurs données. Exercice : Expliquez si les services ISO 27002 étudiés en cours auraient permis (ou pas) d'empêcher la situation de se produire ou d'en limiter les effets.

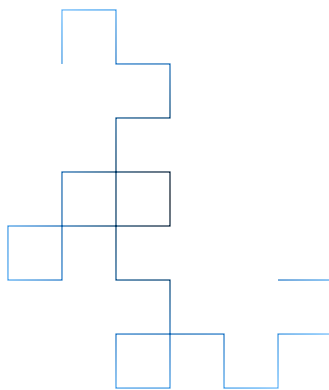
1.1 Question

Le déploiement d'une nouvelle version a corrompu les données de production, sans possibilité de restauration : les vendeurs ont dû ressaisir leurs données. L'incident touche l'intégrité et la disponibilité des données ; pas la confidentialité. Dont l'origine est les pratiques de changement, de test et de sauvegarde autour du déploiement.

La norme ISO 27002 distingue contrôles préventifs, de détection et correctifs. On peut donc diviser la question en deux :

- Quels contrôles auraient empêché la corruption des données ?
- Quels contrôles auraient limité ses effets une fois survenue ?

ISO 27002



La norme ISO 27002 définit plusieurs recommandations quant à l'intégrité des données et aux relations avec les entreprises tierces contractées pour ce genre de réalisation.

On peut isoler les éléments suivants :

2.1 Sauvegarde des Informations

Une simple sauvegarde des données aurait complètement annulé le problème.

La norme ISO indique :

A topic-specific policy on backup should be established to address the organization's data retention and information security requirements. Adequate backup facilities should be provided to ensure that all essential information and software can be recovered following an incident or failure or loss of storage media

[...]

c) storing the backups in a safe and secure remote location, at a sufficient distance to escape any damage from a disaster at the main site;

— 8.13 [1]

La norme recommande d'avoir plusieurs sauvegardes placées à des lieux différents pour éviter de toutes les perdre en cas d'événement grave (ex. tremblement de terre, inondation, ...).

ISO ne donne pas de recommandation pratique sur comment opérer ces systèmes de sauvegarde. Cependant, l'ANSSI [2] dispose d'un guide qui détaille, de manière non technique, les meilleures pratiques quant aux sauvegardes.

2.2 Changement de Gestion

La source spécifique de l'incident provient d'une entreprise tierce qui venait effectuer un service de migration. La norme décrit comment ces changements aux systèmes devraient être opérés.

Introduction of new systems and major changes to existing systems should follow agreed rules and a formal process of documentation, specification, testing, quality control and managed implementation. Management responsibilities and procedures should be in place to ensure satisfactory control of all changes.

Change control procedures should be documented and enforced to ensure the confidentiality, integrity and availability of information in information processing facilities and information systems, for the entire system development life cycle from the early design stages through all subsequent maintenance efforts.

— 8.32 [1]

Ici, la norme spécifie que les changements doivent être documentés et testés.

2.3 Ségrégation des environnements de développement et production

Without adequate measures and procedures, developers and testers having access to production systems can introduce significant risks (e.g. unwanted modification of files or system environment, system failure, running unauthorized and untested code in production systems, disclosure of confidential data, data integrity and availability issues). There is a need to maintain a known

and stable environment in which to perform meaningful testing and to prevent inappropriate developer access to the production environment.

— 8.31 [1]

2.4 Relation fournisseur/client

Note : même ayant suivi des cours de droit, je ne suis pas un expert ou même qualifié en matière de législation. J'ai donc demandé à un ami avocat de m'aider sur cette partie.

L'entreprise évryste s'expose à des actions punitives et dédomagement. Conformément au code civil ; art.1217-C : l'entreprise AlphaBeta peut refuser ou suspendre l'exécution de ses obligations (ici obligation de paiement pour les services), exiger une réduction du prix ou demander la réparation des conséquences ainsi que résoudre le contrat.

Dans le contexte, il est probable que AlphaBeta demande une réduction du prix et suspende ses obligations le temps de restaurer les données. La startup EvryTop sera contrainte de restaurer les systèmes sans gratification. AlphaBeta a également le droit de refuser de travailler avec EvryTop, et exiger l'intervention d'une autre entreprise, à charge d'EvryTop.

art.1231-3

Le débiteur n'est tenu que des dommages et intérêts qui ont été prévus ou qui pouvaient être prévus lors de la conclusion du contrat, sauf lorsque l'inexécution est due à une faute lourde ou dolosive.

— art.1231-3 Code Civil

Ce qui indique que les dommages éventuels devaient être prévus de le contrat signé par EvryTop et AlphaBeta, hors faute grave ou dolosive. Il faut donc déterminer dans le contexte la nature de la faute. [détailler]

art.1170 Toute clause qui prive de sa substance l'obligation essentielle du débiteur est réputée non écrite.

Dans le cadre de la migration de donnée, l'intégrité des données est jugée comme une obligation essentielle, ainsi la perte des données peut être considérée comme faute lourde (négligence).

Pour compléter le point évoqué sur art.1217-C,

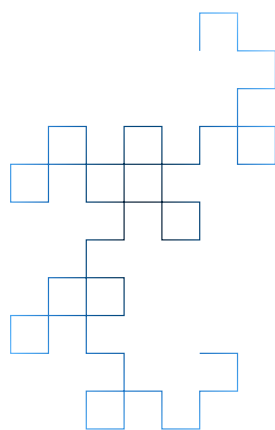
voir l'arrêt du 22 octobre 1996 de la cour de Cassation

art.1231-5

Cependant, il est important de noter l'obligation de moyens contre l'obligation de résultats. Si AlphaBeta n'avait pas donné à EvryTop les moyens de faire des sauvegardes, alors la responsabilité et l'obligation de produire un résultat d'EvryTop est réduite.

Également, si les bases de données contenaient des informations personnelles, la législation impose le signalement de l'incident à la CNIL, conformément à la RGPD (art.34).

Analyse d'un cas réel : TSB 2018



Le problème survient lorsque l'entreprise change de fournisseur de services pour cette infrastructure.

Références

- [1] “Information security, cybersecurity and privacy protection — Information security controls.” [Online]. Available: <https://www.iso.org/standard/75652.html>
- [2] “Sauvegarde des systèmes d’information | MesServicesCyber.” Accessed: Sep. 18, 2026. [Online]. Available: <https://messervices.cyber.gouv.fr/guides/fondamentaux-sauvegarde-systemes-dinformation>